

Universidad de la
Defensa Nacional

FADENA

Ciberseguridad aplicada

Clase 4: Gestión de identidades y accesos

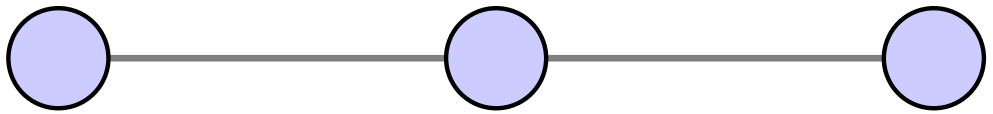
Unidad VI: Gestión de identidades y accesos

7 de septiembre de 2026

Ruta de la Clase 4: Unidad VI

UNIDAD VI Teoría	**UNIDAD VI Práctica**
Gestión de identidades y accesos  Usted está aquí	Práctica : Instalación y configuración de una máquina virtual Práctica: IAM en la terminal.

Recorrido de la Unidad VI (Teoría)



Tema 1
Gestión de identidades

Tema 2
Gestión de usuarios

Tema 3
Gestión de accesos

Tema 1 Gestión de identidades
Tema 2 Gestión de usuarios
Tema 3 Gestión de accesos

1. Tema 1: Gestión de Identidades
   - Niveles de Aseguramiento
   - Autenticación
2. Tema 2: Gestión de Usuarios
   - Tipos de usuarios
   - Responsabilidades, obligaciones y funciones del usuario
   - Gestión de terceros
     - Acuerdos de nivel de servicio (SLA)
   - Centralización de usuarios
3. Tema 3: Gestión de acceso
   - RBAC
   - ABAC
   - ACL
   - Ejemplo de mecanismo técnico para gestión de accesos

Gestión de identidades y accesos

Aclaración

- En la práctica profesional este enfoque se conoce como **IAM**
- Proviene del inglés: *Identity and Access Management*
- IAM no es un único estándar, protocolo o tecnología
- Es un concepto integrador que comprende, entre otros aspectos:
  - Gestión de identidades
  - Gestión de cuentas y credenciales
  - Autenticación
  - Autorización y control de acceso

Importante

- IAM permite gestionar **quién** puede acceder a **qué recursos**, **bajo qué condiciones** y con qué nivel de privilegios.

IAM = Identidades + Autenticación + Autorización + Control

Alcance del contenido: tres componentes

En el marco de IAM podemos distinguir distintos componentes que están relacionados, pero cumplen funciones diferentes:

Gestión de identidades (Identity Management): Se ocupa de definir y administrar la identidad digital de una entidad, como una persona, un sistema o un servicio. Incluye sus atributos, roles y el ciclo de vida de la identidad.

Gestión de usuarios (User Management): Se ocupa de administrar las cuentas asociadas a esas identidades dentro de los sistemas: altas, modificaciones y bajas.

Gestión de accesos (Access Management): Se ocupa de determinar y controlar a qué recursos puede acceder una identidad, bajo qué condiciones y con qué privilegios.

Tres conceptos para diferenciar

Los conceptos están relacionados, pero cumplen funciones distintas y no deben tratarse como un único procedimiento.

Son complementarios, pero no equivalentes:

- **Identidad** → quién es
- **Usuario** → cómo se representa en el sistema
- **Acceso** → qué puede hacer

Gestión de Identidades

Gestión de Identidades

Preguntas clave

¿Quién es la entidad?
¿Cómo se define su identidad digital?
¿Qué atributos la describen de forma unívoca?

Objetivo: Definir identidades digitales únicas y consistentes para cada entidad, como base para la creación de usuarios y los mecanismos de autenticación y control de acceso.

Identidad digital

- Conjunto de atributos que describen a una entidad dentro de un sistema
- Permite identificar de forma unívoca a una persona, sistema o dispositivo

Ejemplos de atributos

- Nombre y apellido
- Documento o legajo
- Rol organizacional
- Área o dependencia
- Identificador de dispositivo o sistema

Importante

- La identidad no es la cuenta ni el usuario

Definición de identidad digital (NIST)

Identidad digital [1]

- Representación única de un sujeto en una transacción digital
- Es dependiente del contexto (servicio)
- No implica necesariamente conocer la identidad real

Procesos asociados

- Verificación de identidad (Identity Proofing)
- Autenticación (Authentication)

Niveles de Aseguramiento de Identidad (IAL)

IAL (Identity Assurance Level)

- IAL1: Identidad no verificada (atributos auto-declarados)
- IAL2: Identidad verificada (remota o presencial)
- IAL3: Identidad verificada con presencia física obligatoria

Interpretación

- Define el nivel de confianza en la identidad del usuario
- Depende del riesgo asociado al servicio

Autenticación

La autenticación es el proceso mediante el cual se valida la identidad de una entidad (usuario, sistema o dispositivo), asegurando que corresponde a la identidad declarada.

Autenticación

Definición

- Proceso de verificación de identidad
- Responde a la pregunta: *¿Es quien dice ser?*

Buenas prácticas

- Mayor exigencia para identidades que tienen usuarios privilegiados: Uso de autenticación multifactor (MFA)

Factores de autenticación

- Algo que sabe (contraseña)
- Algo que tiene (token, celular)
- Algo que es (biometría)

Gestión de usuarios

Gestión de Usuarios

Es fundamental comprender que una incorrecta definición del procedimiento de gestión de usuarios puede tener consecuencias legales y económicas significativas.

La falta de formalización, firmas de conformidad o documentación adecuada por parte de los usuarios puede derivar en vulnerabilidades jurídicas, pérdida de evidencia de cumplimiento y potenciales daños económicos relevantes para la organización.

Usuarios

Existen varios roles/perfiles, a priori mínimo:

1. Usuario estándar
2. Usuario privilegiado (administrador, operador con permisos de configuración, gestión de los dispositivos de la organización, acceso root)

Obligaciones, responsabilidades y funciones

Cada usuario debe saber qué puede hacer y qué se espera de él.

Antes de acceder

- Conocer sus responsabilidades
- Conocer sus obligaciones
- Conocer sus funciones

Durante el alta

- Las condiciones deben estar formalizadas
- El usuario debe tomar conocimiento
- Debe aceptar las condiciones establecidas

¿A quiénes aplica?

Empleados, contratistas, proveedores y otros terceros que tengan acceso a los recursos de la organización.

Contenido de obligaciones, responsabilidades y funciones

Esto no solo fortalece la seguridad organizacional, sino que también resulta clave desde el punto de vista legal, ya que permite demostrar que el usuario fue debidamente informado.

En ausencia de esta formalización, la organización queda expuesta a riesgos legales, pudiendo ver debilitada su posición ante incidentes o conflictos derivados del uso indebido de los sistemas

Riesgo Legal del Procedimiento

Punto crítico:

- El usuario debe **firmar** conocimiento del procedimiento

Riesgos si no existe:

- Responsabilidad legal de la organización
- Pérdida de demandas judiciales
- Impacto económico significativo

Principio:

- "Lo no documentado, no existe jurídicamente"

Importancia jurídica

- Lo no informado puede generar conflictos legales
- El desconocimiento habilita reclamos del usuario
- La firma implica aceptación de responsabilidades

Buena práctica:

- Incorporar anexo firmado al alta
- Incluirlo en contratos de terceros

Documento de aceptación de uso y responsabilidades

Elementos mínimos que debe contener el documento de procedimientos [2]:

- Acceso físico
- Identificación y credenciales
- Responsabilidades sobre activos
- Prohibiciones
- Confidencialidad de la información
- Destrucción de soportes
- Propiedad intelectual
- Gestión de incidentes
- Uso del correo electrónico
- Acceso a internet

Acceso físico

- Definición de áreas habilitadas y restringidas
- Mecanismos de autenticación:
  - Credencial
  - Llave electrónica
  - Biometría

Consideraciones:

- Señalización de áreas restringidas
- Videovigilancia informada y consentida

Credenciales de usuario

- Indicadores de usuarios y claves de acceso
- Uso personal e intransferible
- Prohibición de compartir credenciales
- Notificación ante sospecha de compromiso

Responsabilidades sobre activos

- Protección de equipos e información
- Uso de antivirus
- Reporte de anomalías
- Apagado de equipos

Gestión de activos:

- Aclarar que puede o no hacer sobre los activos de la organización
- Recepción, uso y devolución
- Responsabilidad sobre activos asignados

Prohibiciones

- Uso indebido de internet
- Envío masivo de correos
- Acceso a información de otros usuarios
- Contenidos inapropiados
- Dañar hardware, software o información
- Interrumpir servicios
- Escalar privilegios
- Falsificar registros

Prohibiciones

- Instalar software no autorizado
- Introducir malware o código malicioso
- Modificar configuraciones sin autorización
- Acceder a áreas restringidas

Confidencialidad de la información

- Clasificación de la Información pública, privada y secreta
- Obligación de reserva absoluta
- Aplica durante y después de la relación laboral
- Uso limitado al contexto laboral

Importante:

- No otorga derechos de propiedad sobre la información

Destrucción de soportes

- Eliminación segura de información
- Uso de métodos adecuados de destrucción

Propiedad intelectual

- Uso de software bajo licencias de uso específicas
- Restricción de copia, modificación y distribución sin autorización
- Protección legal de desarrollos, código fuente y activos

Punto clave:

- Los desarrollos realizados en el marco laboral pertenecen a la organización, salvo acuerdo contractual específico que establezca lo contrario.

Gestión de incidentes

- Obligación de reportar incidentes
- Seguir procedimiento definido
- Prohibido actuar sin autorización

Uso del correo electrónico

- El correo corporativo no es privado
- Puede ser monitoreado
- Riesgo de ingreso de malware

Acceso a Internet

- Uso limitado a fines laborales
- Restricción de sitios no autorizados
- Posibilidad de monitoreo

Datos de carácter personal

Ley de Protección de datos personales. ¿Cómo es el tratamiento de los datos personales en la empresa?

- Acceso basado en necesidad de conocer
- Protección según sensibilidad del dato
- Registro de accesos y actividades

Importante:

- Incumplimientos pueden generar sanciones graves

Régimen sancionatorio

- Aplicación según legislación vigente
- Registro formal de evidencias

Tipos de inicio:

- De oficio
- Denuncia interna
- Denuncia externa

Clasificación de sanciones

- Leves
- Graves
- Muy graves

Debe definirse:

- Tipo de infracción
- Sanción aplicable
- Plazos del procedimiento

Gestión de terceros

Concepto

- Proceso para gestionar la relación con terceros que tienen acceso a información, sistemas o servicios de la organización
- Incluye proveedores, contratistas, socios comerciales (partners) y otros terceros
- Define obligaciones, responsabilidades y condiciones de seguridad
- Impacta en la seguridad y continuidad de los procesos.

Objetivo

- Proteger la información y los activos de la organización
- Identificar y controlar los riesgos asociados a terceros
- Establecer condiciones para el acceso a recursos organizacionales
- Mantener el control durante todo el ciclo de la relación

Ciclo de gestión de terceros

Antes

- Evaluar al tercero
- Identificar riesgos
- Definir requisitos
- Establecer condiciones contractuales

Durante

- Controlar accesos
- Supervisar cumplimiento
- Revisar permisos
- Gestionar incidentes

Finalización

- Finalizar accesos
- Recuperar activos
- Revocar credenciales
- Cerrar la relación

Idea clave

La seguridad del tercero debe gestionarse durante **todo el ciclo de la relación**, no solamente al momento de contratarlo.

Riesgos de la externalización

Externalizar no elimina el riesgo: lo transforma

Beneficios

- Especialización
- Reducción de costos
- Mayor capacidad operativa
- Acceso a nuevas tecnologías

Nuevos riesgos

- Nuevas superficies de ataque
- Dependencia del proveedor
- Pérdida de control directo
- Exposición de información y activos

Idea clave

Externalizar implica incorporar al tercero dentro del modelo de riesgo de la organización y establecer controles acordes al servicio.

Acuerdos de Nivel de Servicio (SLA)

¿Qué es?

- Acuerdo que establece los niveles de servicio esperados y las responsabilidades de las partes
- Permite definir cómo se medirá el cumplimiento del servicio

Debe establecer

- Alcance y criticidad del servicio
- Disponibilidad y tiempos de respuesta
- Tiempos de recuperación ante fallos
- Canales y procedimientos de comunicación
- Indicadores y criterios de cumplimiento

SLA: condiciones operativas

El acuerdo debe dejar claro:

- Fecha de inicio y finalización
- Horarios de servicio
- Disponibilidad comprometida
- Tiempos máximos de respuesta
- Procedimientos ante fallos
- Mecanismos de escalamiento
- Responsabilidades del proveedor
- Frecuencia de revisión

Idea clave

Un SLA permite pasar de "el proveedor debe prestar un buen servicio" a **condiciones que pueden medirse y verificarse**.

Control y auditoría del tercero

¿Cómo sabemos que cumple?

- Supervisión del desempeño
- Revisión de indicadores y reportes
- Verificación de controles de seguridad
- Derecho de auditoría cuando corresponda

Objetivo

- Detectar desvíos
- Verificar el cumplimiento contractual
- Obtener evidencia del cumplimiento
- Aplicar medidas correctivas cuando sea necesario

Acceso a información y activos

El acceso del tercero debe estar justificado

- Definido según la función y necesidad del servicio
- Limitado a los recursos necesarios
- Otorgado por el tiempo requerido
- Revisado periódicamente

Principios

- Mínimo privilegio
- Necesidad de conocer
- Según la clasificación de la información
- Trazabilidad de las acciones

Protección de la información

Cuando un tercero accede a información de la organización

- Debe conocer únicamente la información necesaria
- Deben establecerse requisitos de confidencialidad
- Deben aplicarse medidas de seguridad acordes al riesgo
- Deben definirse responsabilidades ante incidentes

Al finalizar la relación

- Devolución o eliminación de la información, según corresponda
- Revocación de accesos
- Recuperación de activos
- Verificación del cierre

Gestión de terceros y datos personales

Cuando un tercero accede a datos personales

- Deben definirse claramente las responsabilidades de cada parte
- El acceso debe limitarse a la finalidad acordada
- Deben establecerse medidas técnicas y organizativas de seguridad

Aspectos a establecer contractualmente

- Finalidad y alcance del tratamiento
- Confidencialidad de la información
- Medidas de seguridad exigibles
- Gestión de incidentes y comunicación
- Devolución o eliminación de los datos al finalizar la relación

Idea clave

El acceso de un tercero a datos personales debe estar **limitado, controlado y formalmente establecido**.

Evaluación del proveedor

Antes de contratar

Capacidad y antecedentes

- Capacidad técnica y operativa
- Experiencia y antecedentes
- Referencias y desempeño previo
- Certificaciones relevantes

Seguridad

- Prácticas y controles de seguridad
- Gestión de incidentes
- Protección de la información
- Requisitos de seguridad aplicables

Personal asignado

Cuando corresponda, también debe verificarse que el personal que tendrá acceso a los sistemas o información posea los **perfiles y competencias requeridos**.

Evaluación de productos y servicios

Antes de incorporar una solución

Evaluación técnica

- Analizar especificaciones y requisitos
- Identificar dependencias y limitaciones
- Evaluar características de seguridad

Validación

- Realizar pruebas en entornos controlados
- Verificar la integración con sistemas existentes
- Comprobar el cumplimiento de los requisitos

Idea clave

No alcanza con que el proveedor sea confiable: el producto o servicio también debe ser **adecuado y seguro para el entorno de la organización**.

Transferencia de conocimiento

¿Qué riesgo aparece?

- Dependencia del conocimiento del proveedor
- Dificultad para operar o mantener el servicio sin él
- Riesgo de pérdida de conocimiento ante la finalización del contrato

¿Cómo gestionarlo?

- Establecer cláusulas de transferencia de conocimiento
- Documentar procedimientos, configuraciones y arquitectura
- Definir planes de capacitación para el personal interno
- Establecer mecanismos de transición al finalizar el contrato

Idea clave

El conocimiento necesario para mantener un servicio crítico no debería quedar exclusivamente en manos del proveedor.

Gestión de cuentas externas

Riesgos

- Cuentas activas después de finalizar el contrato
- Accesos que dejan de ser necesarios
- Privilegios excesivos o cuentas compartidas

Controles

- Altas, bajas y modificaciones controladas
- Accesos asociados a una identidad individual
- Revisión periódica de permisos
- Integración con procesos de IAM

Punto crítico

Cuando termina la relación con un tercero, sus accesos deben ser **revocados de manera oportuna**.

Finalización del contrato

La relación termina, pero el control de seguridad continúa

Aspectos contractuales

- Rescisión por incumplimiento
- Cumplimiento de obligaciones pendientes
- Devolución de activos
- Tratamiento de la información

Aspectos de seguridad

- Revocación de cuentas y credenciales
- Retiro de permisos y accesos
- Eliminación segura de información
- Verificación del cierre de accesos

Idea clave

La finalización de un contrato debe incluir también una **finalización controlada de los accesos**.

Reducción de la dependencia del proveedor

Objetivo

Reducir el riesgo de quedar atado a un único proveedor.

Estrategias

- Priorizar estándares abiertos e interoperables
- Evitar dependencias tecnológicas innecesarias
- Mantener documentación técnica completa
- Asegurar la portabilidad de datos y configuraciones
- Conservar conocimiento y capacidades dentro de la organización

Idea clave

La organización debe conservar la capacidad de **cambiar de proveedor** sin quedar imposibilitada técnica u operativamente.

Gestión de terceros: aspectos legales

El acceso de terceros debe estar respaldado por condiciones contractuales claras.

Condiciones de acceso

- Alcance y finalidad del acceso
- Información y recursos involucrados
- Obligaciones de confidencialidad
- Requisitos de seguridad

Responsabilidades

- Jurisdicción aplicable
- Penalizaciones por incumplimiento
- Responsabilidad ante incidentes
- Condiciones de finalización del acceso

Idea clave

El tercero no debería recibir un acceso indefinido ni sin condiciones: debe quedar establecido **qué puede hacer, durante cuánto tiempo y bajo qué responsabilidades**.

Centralización de usuarios

Herramienta típica:

- Active Directory (implementa gestión de identidades y accesos)

Ventajas:

- Gestión centralizada
- Automatización de altas/bajas
- Asignación de roles

Impacto:

- Reducción de errores
- Cumplimiento normativo

Resumen

- Identidades
- Firma obligatoria de usuarios: Procedimiento formal y documentado
- Separación del tratamiento de usuario vs acceso

Gestión de accesos

Gestión de accesos

Concepto

- Define a qué recursos puede acceder cada usuario
- Regula permisos sobre sistemas, información y servicios

Idea clave

- Permitir únicamente el acceso necesario
- Restringir todo acceso no autorizado

Gestión de accesos

Concepto central: Asignar a cada usuario exactamente los accesos que necesita. Ni más, ni menos.

Incluye acceso a:

- Dispositivos
- Servicios
- Redes
- Aplicaciones
- Funciones

Idea clave

"Solo accede quien debe hacerlo, con los privilegios necesarios"

ZTA - Zero Trust Arquitectura

Las Arquitecturas zero trust (ZTA), la forma de diseñar los accesos a mi organización sobre la base Confianza Cero. No confiar en nadie.

Empezar cerrando todo y abrir a medida que el usuario cumpla las condiciones que yo quiera que cumpla esas condiciones de accesos lógico o físico.

Zero Trust

Modelo tradicional (confianza implícita)

- Se valida el acceso en el perímetro de la red
- Una vez autenticado, se asume confianza interna
- Movimiento lateral con controles limitados

Modelo Zero Trust

- No existe confianza implícita por ubicación de red
- Verificación continua de identidad, dispositivo y contexto
- Acceso mínimo necesario (principio de menor privilegio)
- Controles de acceso aplicados en cada solicitud

Idea clave

- *Nunca confiar, siempre verificar*

Gestión de accesos - Procedimiento

Un documento de gestión de accesos debe contemplar:

1. Existe un documento de control de accesos
2. Pasos definidos para solicitud, administración y anulación de los derechos de acceso (procesos de alta, modificación y baja)
3. Debe existir el rol de gestor de usuarios
4. Ciclo de vida de cuentas [a]
5. Uso de herramientas de workflow [b] para control de acceso
6. Perfilado de usuarios (roles) [a]
7. Integración con sistemas (AD, LDAP, RRHH) [b]
8. Eliminación de cuentas genéricas
9. Uso riguroso de privilegios
10. Ventanas de acceso para tareas críticas
11. Granularidad en accesos
12. Plataformas de trazabilidad
13. Controles ante evasión

[a] Plan - Do - Check - Act

[b] Sistema de Ticket

[a] lectura, mantenimiento estándar, manten. avanzado, administrador, etc.

[b] AD: Active Directory; LDAP: protocolo de directorio; RRHH: Recursos Humanos

Conceptos clave

Elementos fundamentales

- **Granularidad** → acceso específico y controlado
- **Privilegios** → según rol y necesidad
- **Trazabilidad** → registro completo de accesos
- **Ciclo de vida** → alta, modificación y baja

Principio de Mínimo Privilegio

Regla fundamental

Cada usuario debe tener:

- Solo los permisos necesarios
- Durante el tiempo necesario

Riesgos de no aplicarlo:

- Accesos excesivos
- Compromiso de cuentas
- Movimiento lateral

Ejemplo: Un usuario administrativo no debería tener acceso a bases de datos críticas.

Autorización

Definición

- Determina a qué recursos puede acceder un usuario
- Responde a la pregunta: *¿Qué puede hacer?*

Ejemplo

- Usuario autenticado correctamente
- Pero con acceso limitado según su rol

Principios clave

- Mínimo privilegio
- Segregación de funciones

Autenticación vs Autorización

Autenticación	**Autorización**
¿Quién sos?	¿Qué podés hacer?
Verifica identidad	Define permisos
Inicio de sesión	Acceso a recursos

Control de Accesos

Modelos de control de acceso

- Control de acceso basado en roles (RBAC - Role Based Access Control)
- Control de acceso basado en atributos (ABAC - Attribute Based Access Control)
- Listas de control de acceso (ACL - Access Control Lists)

Objetivo

- Garantizar acceso legítimo
- Bloquear accesos indebidos

Mecanismos técnicos

- Autenticación (contraseña, MFA, certificados)
- Sistemas de gestión de identidades (IAM)
- Control de acceso a red (ej: 802.1X)
- Segmentación de red (VLANs, zonas de seguridad, microsegmentación)
- Firewalls y filtrado de tráfico
- Sistemas de autorización en aplicaciones

Objetivo

- Implementar y hacer cumplir las políticas de acceso

Control de acceso basado en roles (RBAC)

- Rol → función dentro de la organización
- Permisos → acciones (leer, escribir, ejecutar)
- Los permisos se asignan a roles preestablecidos (administrador, analista,usarios)
- Los usuarios se asignan a roles

Modelo

$$\text{Usuario} \rightarrow \text{Rol} \rightarrow \text{Permisos} \rightarrow \text{Recurso}$$

Implementación en sistemas

- Los roles suelen implementarse mediante grupos
- Ejemplo: grupo analistas con permisos de lectura sobre logs

Idea clave Los usuarios no reciben permisos directamente, sino a través de roles. Es decir, el modelo asigna permisos a roles (por ejemplo, administrador, analista), y los usuarios heredan esos permisos al ser asignados a dichos roles

Control de acceso basado en atributos (ABAC)

- El acceso se decide en función de atributos
- Los atributos pueden pertenecer al usuario, al recurso o al entorno

Ejemplos de atributos

- Usuario → área, rol, nivel de autorización
- Recurso → clasificación, tipo de información
- Entorno → horario, ubicación, dispositivo

Modelo

$$\text{Usuario} + \text{Contexto} \rightarrow \text{Políticas} \rightarrow \text{Decisión de acceso}$$

Idea clave

- El acceso no depende solo de quién es el usuario, sino también de las condiciones en el momento del acceso

Listas de control de acceso (ACL)

- Define permisos directamente sobre un recurso
- Especifica qué usuarios o grupos pueden acceder y qué pueden hacer

Estructura

- Recurso → lista de entradas de control de acceso
- Cada entrada define:
  - Sujeto (usuario o grupo)
  - Permisos (leer, escribir, ejecutar)

Modelo

$$\text{Recurso} \rightarrow \text{Lista de permisos} \rightarrow \text{Usuario}$$

Idea clave

- El control de acceso se define directamente sobre cada recurso

Ejemplo: Segmentación de red

La segmentación de red (mecanismo de control) permite estructurar canales controlados de acceso, restringiendo la comunicación entre zonas y reforzando las políticas definidas en la gestión de identidades y accesos.

Concepto

Separación de la red en zonas con diferentes niveles de acceso y seguridad.

Objetivo

- Controlar accesos
- Limitar impacto de incidentes
- Diferenciar funciones

Ejemplo: servidor web

Accesos desde distintas zonas

- Usuarios externos - Internet $\rightarrow$ servicio público (DMZ) - Servidor web
- Usuario internos - Intranet (Red interna) $\rightarrow$ Servidor web
- Servidor web $\rightarrow$ consulta a la base datos $\rightarrow$ zona interna (MZ)
- Administración $\rightarrow$ se conecta al servidor web para gestionar $\rightarrow$ red de gestión

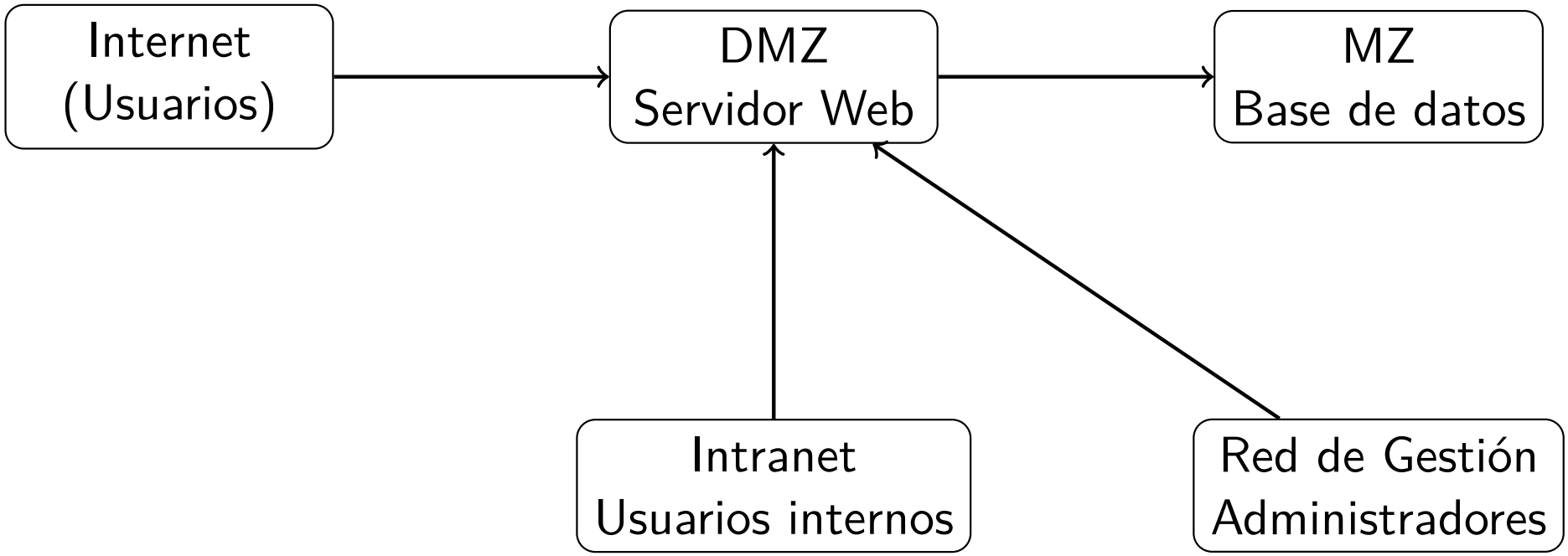
Segmentación aplicada

Mismo recurso, distintos accesos

Servidor Web

- Acceso externo (usuarios)
- Acceso interno (empleados)
- Acceso backend (servicios)
- Acceso administrativo (gestión)

Segmentación de red: esquema



Idea clave: Un mismo recurso puede tener múltiples accesos controlados

Valor de la segmentación

Beneficios

- Mayor control de accesos
- Reducción de superficie de ataque
- Aislamiento de incidentes
- Mejora en monitoreo y control

Idea clave

$$\text{Segmentar} = \text{aumentar seguridad}$$

Resumen - Gestión de identidades y accesos

Preguntas clave

- ¿Quién es el sujeto? (Identidad)
- ¿Cómo se representa en el sistema? (Usuario)
- ¿Cómo demuestra su identidad? (Autenticación)
- ¿A qué puede acceder? (Autorización)

Idea central

La identidad es un conjunto de atributos. El usuario es su representación operativa en un sistema.

Muchas gracias

Retomamos las actividades en el campus virtual. Ya se encuentra disponible una autoevaluación para reforzar los conceptos.

Para pensar e investigar:

- ¿Qué usuarios existen en su computadora y qué permisos tiene cada uno?



Referencias I


Paul A. Grassi, Michael E. Garcia, and James L. Fenton.
Digital Identity Guidelines.
https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63-3.pdf, 2017.
Accedido: 2026.


Alejandro Corletti Estrada.
Manual de Resiliencia en Redes y Sistemas de TI.
https://adsi.pro/wp-content/uploads/descargas/Manual_de_Resiliencia_Internet.pdf, 2020.
Accedido: 2026.